

1. RELEVAMIENTO PREVIO DE LA SITUACIÓN ACTUAL

1.1 Descripción general de la organización

Vitalis es una organización dedicada a la prestación de actividades físicas y recreativas. Su operatoria diaria comprende la administración de alumnos, el registro de pagos, la planificación de actividades, la gestión de profesores y el control de ingresos y egresos financieros.

Durante el relevamiento se observó que gran parte de los procesos administrativos se realizan mediante archivos Microsoft Excel utilizados como herramienta principal de gestión. Estos archivos contienen información crítica para el funcionamiento de la organización y constituyen el principal repositorio de datos institucionales.

La estructura organizacional identificada está compuesta por:

- Dirección o responsables administrativos.
- Personal administrativo.
- Profesores e instructores.
- Alumnos o clientes.

Los procesos considerados críticos para la continuidad operativa son:

- Gestión de alumnos.
- Registro y seguimiento de pagos.
- Administración financiera.
- Planificación de actividades.
- Gestión de horarios y profesores.
- Conservación de información histórica.

1.2 Metodología utilizada para el relevamiento

El relevamiento fue realizado mediante observación directa y análisis documental de los recursos utilizados por la organización.

Las actividades desarrolladas fueron:

- Revisión de archivos Excel utilizados en la operación diaria.
- Identificación de activos de información.
- Análisis de procesos administrativos reflejados en las planillas.
- Identificación de amenazas y vulnerabilidades.
- Evaluación preliminar de controles existentes.

La información analizada provino principalmente de los archivos:

- LISTA DE ALUMNOS.xlsx

- Planificación de todas las actividades.xlsx

Asimismo, se consideró la infraestructura tecnológica utilizada por la organización para almacenar y gestionar la información.

1.3 Inventario de activos de información

Se identificaron los siguientes activos críticos:

ID	Activo	Tipo	Criticidad
A1	Base de alumnos	Información	Alta
A2	Información financiera y pagos	Información	Alta
A3	Archivos Excel institucionales	Información	Alta
A4	Planificación de actividades	Información operativa	Media
A5	Equipos administrativos	Hardware	Alta
A6	Información de profesores	Información	Media
A7	Red WiFi institucional	Infraestructura de red	Alta
A8	Servicio de Internet	Servicio	Alta

Base de alumnos

Contiene información identificatoria de los alumnos, registros administrativos y seguimiento de pagos.

Información financiera

Incluye registros de ingresos, egresos, liquidaciones y control económico de la organización.

Archivos Excel institucionales

Constituyen el principal repositorio de información utilizado para gestionar las operaciones diarias.

Equipos administrativos

Dos computadoras administrativas utilizadas para almacenar y procesar toda la información de clientes, pagos, actividades y documentación interna.

Red WiFi institucional

Red utilizada para brindar conectividad a Internet tanto a clientes como a personal administrativo.

1.4 Situación actual de seguridad

Gestión de la información

La organización utiliza hojas de cálculo Excel como principal herramienta de administración, almacenamiento y consulta de información.

Control de acceso

No se identificaron mecanismos formales de control de acceso basados en roles ni restricciones específicas para la modificación de archivos.

Protección de datos

Los datos personales de alumnos, profesores y la información financiera se encuentran almacenados en archivos susceptibles de ser modificados o eliminados sin controles avanzados de seguridad.

Respaldo de información

No se observaron procedimientos documentados de respaldo, recuperación o continuidad operativa.

Trazabilidad

No existen mecanismos de auditoría que permitan identificar quién realizó modificaciones sobre los registros almacenados.

Infraestructura de red y conectividad

Durante el relevamiento se identificó que la organización utiliza una red WiFi abierta para brindar acceso a Internet.

Las dos computadoras administrativas utilizadas para gestionar toda la información institucional se encuentran conectadas a esta misma red, compartiendo infraestructura con dispositivos utilizados por alumnos y visitantes.

No se observaron mecanismos de segmentación de red, redes separadas para invitados, controles de acceso avanzados ni políticas de seguridad específicas para el acceso inalámbrico.

Esta situación incrementa significativamente la superficie de exposición frente a accesos no autorizados, interceptación de comunicaciones, propagación de malware y potencial compromiso de información sensible.

1.5 Controles existentes identificados

Durante el relevamiento se identificaron únicamente controles básicos:

Control	Estado
Registro manual de información	Implementado
Organización de datos mediante Excel	Implementado
Copias manuales de archivos	Parcialmente implementado
Control formal de accesos	No identificado
Auditoría de cambios	No identificada
Segmentación de red	No identificada
Gestión documentada de respaldos	No identificada
Plan de continuidad operativa	No identificado
Capacitación en ciberseguridad	No identificada

1.6 Evidencias recolectadas

Las evidencias utilizadas para el análisis fueron:

- Archivo LISTA DE ALUMNOS.xlsx.
- Archivo Planificación de todas las actividades.xlsx.
- Inventario de activos identificado durante el relevamiento.
- Matriz de riesgos elaborada mediante metodología Pirani.
- Mapa de calor de riesgos.
- Observación de la infraestructura de red utilizada por la organización.

1.7 Conclusión del relevamiento

El relevamiento permitió determinar que la información crítica de Vitalis se encuentra altamente centralizada en archivos Excel y almacenada en equipos administrativos conectados a una red WiFi abierta compartida con usuarios externos.

La ausencia de controles de acceso, mecanismos de auditoría, segmentación de red y procedimientos formales de respaldo incrementa significativamente la exposición de la organización frente a amenazas que pueden afectar la confidencialidad, integridad y disponibilidad de la información.

Estos hallazgos constituyen la base para el análisis de riesgos desarrollado en la siguiente sección.

2. ANÁLISIS DE RIESGOS

2.1 Metodología utilizada

La evaluación de riesgos se realizó utilizando una metodología basada en los principios establecidos por ISO 27001 y adaptada a la herramienta Pirani Risk.

Cada riesgo fue analizado considerando:

- Activo afectado.
- Amenaza.
- Vulnerabilidad.
- Consecuencia.
- Probabilidad de ocurrencia.
- Impacto sobre la organización.

La valoración fue realizada mediante una matriz de probabilidad e impacto de cinco niveles.

El riesgo inherente fue calculado mediante la multiplicación entre probabilidad e impacto.

2.2 Riesgos identificados

Se identificaron doce riesgos relevantes para la organización.

R1 – Acceso no autorizado a datos de alumnos

La ausencia de controles de acceso adecuados puede permitir que personas no autorizadas accedan a información personal de alumnos.

Clasificación: Crítico.

R2 – Pérdida de información por falla de hardware

La falta de respaldos formales puede ocasionar la pérdida total de información institucional.

Clasificación: Crítico.

R3 – Manipulación indebida de pagos y liquidaciones

La inexistencia de mecanismos de auditoría facilita modificaciones no autorizadas sobre registros financieros.

Clasificación: Crítico.

R4 – Infección por ransomware

Un ataque de ransomware podría paralizar completamente la operación administrativa y bloquear el acceso a la información.

Clasificación: Crítico.

R5 – Exposición de datos por error humano

La gestión manual de archivos incrementa el riesgo de compartir información sensible por error.

Clasificación: Alto.

R6 – Errores en la registraci3n de pagos

Los procesos manuales aumentan la probabilidad de inconsistencias financieras.

Clasificaci3n: Alto.

R7 – Robo o p3rdida de dispositivos

La p3rdida de equipos administrativos podr3a exponer informaci3n sensible almacenada localmente.

Clasificaci3n: Alto.

R8 – Eliminaci3n accidental de archivos

La ausencia de controles de recuperaci3n y versionado puede afectar la continuidad operativa.

Clasificaci3n: Alto.

R9 – Modificaci3n no autorizada de cronogramas

La planificaci3n de actividades puede ser alterada sin mecanismos de validaci3n adecuados.

Clasificaci3n: Medio.

R10 – Dependencia operativa de archivos Excel

La organizaci3n depende casi exclusivamente de archivos Excel para gestionar sus procesos cr3ticos.

Clasificaci3n: Cr3tico.

R11 – Acceso no autorizado a la red inal3mbrica

La utilizaci3n de una red WiFi abierta permite que cualquier persona dentro del alcance de la se3al pueda conectarse a la infraestructura de red.

Esto incrementa significativamente el riesgo de accesos indebidos a recursos internos.

Clasificaci3n: Cr3tico.

R12 – Compromiso de informaci3n por falta de segmentaci3n de red

La red utilizada por clientes y visitantes es la misma utilizada por las computadoras administrativas que almacenan informaci3n financiera y datos personales.

La ausencia de segmentaci3n facilita intentos de acceso, interceptaci3n de tr3fico y propagaci3n de malware hacia los equipos administrativos.

Clasificaci3n: Cr3tico.

2.3 Resultados obtenidos

Los resultados obtenidos muestran una elevada concentración de riesgos en niveles de criticidad alta y crítica.

Del total de riesgos identificados:

- 7 riesgos fueron clasificados como Críticos.
- 4 riesgos fueron clasificados como Altos.
- 1 riesgo fue clasificado como Medio.

Los principales factores de riesgo identificados fueron:

- Dependencia de archivos Excel como sistema de gestión.
 - Ausencia de controles de acceso.
 - Falta de respaldos formales.
 - Ausencia de auditoría y trazabilidad.
 - Utilización de una red WiFi abierta compartida entre clientes y administración.
 - Falta de segmentación de red.
-

2.4 Conclusión del análisis

El análisis realizado demuestra que Vitalis presenta un nivel significativo de exposición frente a amenazas que pueden afectar la confidencialidad, integridad y disponibilidad de la información.

El riesgo más relevante identificado corresponde a la utilización de una red WiFi abierta compartida entre usuarios externos y equipos administrativos que almacenan información financiera y datos personales de alumnos.

Asimismo, la dependencia de archivos Excel como principal herramienta de gestión y la ausencia de controles formales de seguridad incrementan considerablemente el impacto potencial de incidentes de ciberseguridad.

Por lo tanto, se recomienda implementar medidas orientadas al fortalecimiento de la seguridad de la red, segmentación de accesos, gestión de respaldos, control de permisos y protección de la información crítica de la organización.